

Company XYZ

Risk and Compliance Committee (RCC) Charter

<i>Title</i>	<i>Risk Compliance Committee Terms of Reference</i>
<i>Date of last revision</i>	<i>April, 2025</i>
<i>Document classification</i>	<i>Confidential</i>
<i>Version</i>	<i>3.0</i>
<i>Approval Date</i>	<i>April 2025</i>
<i>Next scheduled review</i>	<i>April, 2026</i>
<i>Document description</i>	<i>The purpose of this document is to outline the terms of reference for the Group Risk and Compliance Committee</i>

Contents

1. Purpose	3
2. Membership	3
2.1. RCC Review and attendance	4
3. Roles & Responsibilities	4
3.1. CEO & SEO	4
3.2. The Head of InfoSec	4
3.3. Head of Compliance	5
3.4. Chief Legal Officer and Head of Risk	5
4. Policies/Strategies Allocated for Discussion and Approval	6

1. Purpose

The Risk and Compliance Committee ("**RCC**") is responsible for assisting the Board of Directors ("**Board**") in its oversight of risk, reviewing the Lean Technology group of companies (hereafter referred to as the "**Group**") risk appetite and risk profile in relation to capital, liquidity and revenue generation, reviewing the effectiveness of the Group's risk management framework, reviewing the methodology used in determining the Group's capital requirements, stress testing, ensuring due diligence appraisals are carried out on strategic or significant business relationships, clients and transactions, in order to ensure that risk management is properly considered in setting the Group's remuneration policy, and monitoring prudential regulatory requirements across the Group.

Primary responsibility for setting the Group's conduct and financial crime risk appetites and overseeing the Group's profile against them; overseeing the brand and reputation of the Group and ensuring that the reputational risk is consistent with the risk appetite lies with the Board.

1.1 RCC Objectives

The RCC is collectively responsible for performing the following activities:

- Review and Approve Lean cybersecurity strategy
- Review and approve Lean risk management framework and risk appetite
- Review Group level threats and risks (including internal and external ones)
- Review and monitor compliance against applicable Group level cybersecurity regulations and laws (e.g. ISO27001, SAMA CSF, NCA ECC, SAMA OB Framework)
- Establish and support the maintenance of an Information Security Management System compliant with applicable KSA and SAMA regulations and ISO27001
- Recommend policies and standards,
- Review the cyber security strategy to ensure that it supports Lean Technologies objectives
- Monitor, review and communicate Lean's cyber security risk appetite periodically or upon a material change in the risk appetite;
- Approve, Communicate, Support and monitor:
 - The cyber security governance;
 - The cyber security strategy;
 - The cyber security policy;
 - Cyber security programs (e.g., awareness program, data classification program, data privacy, data leakage prevention, key cyber security improvements);
 - Cyber security risk management process;
 - The key risk indicators (KRIs) and key performance indicators (KPIs) for cyber security.

Note: On an exception basis, policies, procedures, charters can be approved outside the RCC meeting, by a Director.

- Determine program of actions in support of the ISMS and Compliance Monitoring Plan ("**CMP**");
- Recommend priorities for risk management;
- Review handling of security incidents and make recommendations for improvement;
- Review results of Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) as well as any corrective actions required.
- Review results of assessments/audits and approve corrective action plans;

2. Membership

The members, including the chairman of the RCC, shall be appointed by the Board. Members shall be appointed in consultation with the chairman of the RCC.

The RCC shall consist of not less than

The RCC is made up of the following members:

- Mohammed Bevca- Chief Legal Officer and Head of Risk (Committee chair)
- Mohammed Csffs- Chief Executive Officer (CEO and Director)
- Perdds offc - Chief Product Officer (CPO and Director)
- Dominic Damn - Chief Technology Officer (CTO and Director)
- Donte Bark- Head of InfoSec
- Abdulrahman Curf – Head of KSA Security
- Monda Cornfall - KSA Head of Compliance
- Marina Dual - Chief Business Officer (CBO and UAE SEO)

Additional subcommittee members may be invited to attend RCC meetings from time to time, to offer ad hoc departmental input:

- Engineering
- Product
- People & Talent
- Finance
- Information Technology

2.1. RCC Review and attendance

The RCC will meet at least four (4) times each calendar year, and on such other occasions as necessary.

For quorum to be present, each meeting must be attended by at least one Director/SEO.

3. Roles & Responsibilities

3.1. CEO & SEO

In relation to the RCC, the CEO and SEO are accountable for ensuring that Lean devotes sufficient resources to adequately manage the Group's risk and compliance with applicable laws and regulations, including in particular, (but not limited to) information security, data protection and anti-money laundering and counter-terrorist financing risk, including ensuring that the compliance function is appropriately resourced, and that staff receive adequate training.

3.2. The Head of InfoSec

In relation to the RCC, the Head of Infosec is responsible for the following actions:

- Coordination and management of Group risk assessments to identify actual and possible vulnerabilities in Group systems and controls that maybe exploited to cause harm to Group business and/or launder money or finance terrorists.
- Based on the output of such risk assessments, implement a risk management framework to ensure that Lean's systems, applications and controls are not used to exploit identified vulnerabilities.
- Ensure that the risk management framework is proportionate and risk-based, with sufficient resources being devoted to dealing with higher-risk Clients and transactions, as appropriate.
- Ensuring that Lean has appropriate compliance management arrangements, including the appointment of necessary Risk and Compliance Leads within the region of operation.
- Presenting reports, where required, to the leadership team; making recommendations, if any, for action to remedy any deficiencies in the policies, procedures, systems, or controls and following up on those recommendations.
- To consider and advise Lean staff on any aspect of the governance, regulatory, systems and controls, policies and risk management environment (including management of the Risk Register and Risk Appetite) across the Group.

- Responsible for the management and maintenance of the Information Security Management System (ISMS).
- Responsible for the management of the internal audit function.

3.3. Head of Compliance

In relation to the RCC, the Head of Compliance is responsible for the following actions:

- Leading Compliance Department in developing and maintaining an effective open and transparent compliance culture across the Group.
- Ensuring that all staff within the Compliance Department remain fit and proper to complete their duties. Receiving inputs from staff and reporting suspicious transaction reports to the Head of Compliance.
- Developing and maintaining the anti-money laundering and counter-terrorist financing policy and internal procedures in line with applicable legal and regulatory requirements.
- Developing and maintaining an effective anti-money laundering and counter-terrorist financing compliance culture.
- Ensuring adequate documentation and evidence of Lean's risk management policies regarding prevention of money laundering and terrorist financing, risk assessments, and their application.
- Determining and updating a risk-based approach regarding anti-money laundering and counter-terrorist financing and risk assessments of Lean Clients, products, services, delivery channels, and geographic reach.
- Ensuring that all internal suspicious activity reports received are investigated without delay.
- Submitting suspicious transaction reports to the regulatory authority.
- Providing initial and updated training for all staff including the provision of awareness updates to all staff.
- Ensuring that all staff are aware of and are complying with their obligations under the law and the Lean's policies and procedures, and that the basis for the risk-based approach to managing money laundering and terrorist financing risks is understood and applied appropriately across the Group.
- Supporting the business with the assessment of high-risk Clients with respect to anti-money laundering and counter-terrorist financing and Know-Your-Client requirements.
- Presenting reports to leadership team; making recommendations, if any, for action to remedy any deficiencies in the policies, procedures, systems, or controls and following up on those recommendations.
- Representing Lean to all external agencies, for example, supervisory, regulatory, or law enforcement agencies.
- Ensuring that s/he is aware of any relevant sanctions and prohibition, or advisory notices issued by any applicable supervisory agency, or other international agencies such as the FATF.
- Responding promptly to any reasonable request for information from a supervisory, regulatory, and/or law enforcement agency.
- Ensuring that the required screening of all new Client accounts, relationship updates, and ongoing updates of enhanced due diligence and risk assessment reports are carried out in accordance with Lean's applicable policy.
- Ensuring that an automated list of all high-risk Clients is produced and maintained.
- Ensuring that all required updates to any risk assessment report, and/or enhanced monitoring processes are adhered to.

3.4. Chief Legal Officer and Head of Risk

In relation to the RCC, the General Counsel is responsible for the following:

- Provision of advice to the RCC on legal and regulatory requirements and emerging risks to Group business.
- Supporting the assessment of high risk Clients with respect to anti-money laundering and counter-terrorist financing and Know-Your-Client requirements.
- Provision of advice on policies and processes around fraud, cybercrime, theft, bribery, corruption, irregularity, major weakness, or breakdown in the accounting or other control framework and whistleblowing and ensure proper, proportionate, and independent investigation.
- To notify the authorities immediately of the resignation of auditors, or if the Board removes the auditors before the expiry of their term of office.

4. Policies/Strategies Allocated for Discussion and Approval

Including, but not limited to:

- a. Anti-Bribery Policy
- b. Whistleblowing Policy
- c. Anti-money Laundering, Counter-terrorist Financing & Know-Your Client Policy
- d. Compliance Management Plan
- e. Risk and Compliance Manual
- f. Risk Management Policy
- g. Business Continuity and Disaster Recovery Policy and Plans
- h. Privacy Policy
- i. Employee Privacy Notice
- j. Procurement Policy
- k. Annual internal audit strategy
- l. Health and Safety Policy
- m. Information Security Policies (ISO/IEC 27001)
- n. Subcontracting and Supply Chain Policy
- o. Insurance Policies